EXECUTIVE AI BRIEFING / OPERATING CONTROLS

8 AI GOVERNANCE CONTROLS THAT WORK

From ownership and evidence to runtime limits and renewal.

THE EXECUTIVE TEST

Can the business prove a control works when an AI-enabled action actually happens?

01 SEE THE WORK

Visibility and risk classification

01 AI INVENTORY

Record the workflow, AI component, purpose, data, use status and a named process owner.

Proof: reconcile live usage with access and supplier records.

Owner: business process owner

02 RISK CLASSIFICATION

Separate legal classification from operational risk; consider harm, scale, reversibility and autonomy.

Proof: rationale, legal scope screening, renewal trigger.

Owner: process owner + risk advisers

02 TEST THE CONSEQUENCES

People, evidence and release quality

03 IMPACT ASSESSMENT

Examine privacy, people, rights, misuse, accessible recourse and downstream decisions.

Proof: proportional assessment, mitigations, sign-off.

Owner: business + privacy and legal

04 TESTING AND ASSURANCE

Test real tasks, difficult cases, security, fairness, failure recovery and material changes.

Proof: acceptance tests and independent challenge.

Owner: delivery + independent reviewer

03 KEEP ACTIONS WITHIN AUTHORITY

Data and meaningful human intervention

05 DATA CONTROLS

Approve sources, access, purpose, lineage, output handling, retention and leakage safeguards.

Proof: access, deletion and data-quality checks.

Owner: data + security; process owner accountable

06 HUMAN OVERSIGHT

Assign review, escalation, override, suspension and a safe fallback to trained people.

Proof: witnessed stop-and-restore exercise.

Owner: process owner and operational reviewers

04 CONTROL AND RENEW PERMISSION

Runtime checks and independent feedback

07 AGENT AND ACTION CONTROLS

Bind identity, tools, limits, transaction context and separation of duties at execution.

Proof: disallowed and valid-but-wrong actions blocked.

Owner: business defines; security enforces

08 MONITORING AND AUDIT

Observe outcomes, drift, exceptions, incidents and logs; review sampled silent failures.

Proof: alert tests, audit samples and review actions.

Owner: service owner + independent assurance

A PERMITTED ACTION CAN STILL BE THE WRONG ACTION

Check the customer, recipient, amount, timing and business context before execution.

RELEASE GATE APPROVE / LIMIT / REPAIR / STOP



Jair Ribeiro

AI LEADER

Enterprise AI Adoption • Governance • Business Transformation